

THREAT MODEL — ADRION 369

Dokument: Analiza Zagrożeń i Model Przeciwnika
Wersja: 1.0
Standard: STRIDE + ADRION Guardian Compliance

1. Zakres i Założenia

1.1 Co chronimy (Assets)

Asset	Wartość	Skutek kompromitacji
Genesis Record	Krytyczna	Utrata audytowalności, fałszowanie historii decyzji
Wektor PAD (EBDI)	Wysoka	Ominięcie pre-logicznej detekcji zagrożeń
Guardians (G1-G9)	Krytyczna	Wykonanie nielegalnych akcji bez blokady
Trinity Score	Wysoka	Manipulacja wynikiem analizy perspektyw
Klucze kryptograficzne	Krytyczna	Podrabianie podpisów Genesis Record
Agent Swarm (9 agentów)	Wysoka	Przejęcie kontroli nad wykonaniem zadań
SAFE-MCP Protocol	Wysoka	Wstrzyknięcie fałszywych wiadomości między agentami

1.2 Czego nie chronimy (Out of Scope)

- Infrastruktura hosta (odpowiedzialność operatora)
- Bezpieczeństwo fizyczne serwerów
- Ataki na modele LLM zewnętrznych providerów (OpenAI, Anthropic)

2. Model Przeciwnika

2.1 Typy Aktorów

Aktor	Motywacja	Zdolności	Poziom ryzyka
Użytkownik złośliwy	Ominięcie blokad, wymuszenie niedozwolonej akcji	Prompt injection, social engineering	● Wysoki

Aktor	Motywacja	Zdolności	Poziom ryzyka
Insider (operator)	Sabotaż, kradzież danych, manipulacja logami	Dostęp do infrastruktury, kluczy	 Krytyczny
Zewnętrzny atakujący	Przejęcie systemu, data poisoning	Ataki sieciowe, exploity API	 Średni
Konkurencja / APT	Kradzież IP, długoterminowy sabotaż	Zaawansowane, cierpliwe ataki	 Średni
Skompromitowany agent	Propagacja przez swarm	Dostęp do SAFE-MCP bus	 Wysoki

2.2 Założenia o Przeciwniku

- Zna architekturę ADRION 369 (open source — zakładamy pełną wiedzę)
 - Ma nieograniczony czas na testowanie systemu
 - Może wysyłać dowolną liczbę zapytań
 - NIE ma dostępu do kluczy prywatnych Genesis Record (założenie bazowe)
 - NIE może modyfikować kodu w runtime bez wykrycia przez Watchdog
-

3. Wektory Ataku — STRIDE

3.1 Spoofing (Podszywanie)

A-01 — Fałszywy rozkaz (Prawo II bypass)

Opis: Atakujący podszywa się pod autoryzowanego operatora przez deepfake audio/video lub skradziony token.

Cel: Ominięcie weryfikacji G7 (Autonomy)

Wpływ: Wykonanie akcji z uprawnieniami operatora

Mitigacja: Trust_Score wymaga MFA + podpisu kluczem prywatnym
G7 weryfikuje autentyczność przez łańcuch certyfikatów

Guardian: G7 (Autonomy) – BLOKADA przy Trust_Score < 0

A-02 — Podszywanie agenta w SAFE-MCP

Opis: Złośliwy proces wstrzykuje wiadomości do message bus podszywając się pod legalnego agenta swarm.

Cel: Manipulacja wynikiem Debate / Action mode

Wpływ: Wykonanie niezweryfikowanej akcji

Mitigacja: Każda wiadomość SAFE-MCP podpisana kluczem agenta AI-Binder weryfikuje podpis przed dostarczeniem

Guardian: G4 (Causality) – hash required per message

3.2 Tampering (Manipulacja)

A-03 — Manipulacja wektorem PAD (EBDI Poisoning)

Opis: Atakujący kalibruje wektory emocjonalne przez serię specjalnie spreparowanych zapytań, przesuwając baseline PAD w kierunku "wszystko bezpieczne".

Cel: Wyłączenie pre-logicznej detekcji zagrożeń

Wpływ: KRYTYCZNY – system przestaje "czuć" zagrożenia

Mitigacja: Baseline PAD resetowany co 24h z signed checkpoint
Drift > 2σ od baseline → alert + reset + eskalacja
Homeostaza ogranicza maksymalną zmianę per cykl

Guardian: G3 (Rhythm) – monitoring driftu homeostazy

A-04 — Retroaktywna modyfikacja Genesis Record

Opis: Insider próbuje zmodyfikować historyczne wpisy logów aby ukryć złośliwe akcje.

Cel: Zniszczenie audytowalności

Wpływ: Utrata dowodów, niemożność forensics

Mitigacja: Każdy wpis zawiera hash poprzedniego (blockchain-style)
Modyfikacja łamie łańcuch → natychmiastowe wykrycie
3 geograficzne repliki – consensus required for write

Guardian: G4 (Causality) – chain integrity check każde 60s

A-05 — Manipulacja Trinity Score

Opis: Atakujący dostarcza dane wejściowe precyzyjnie skrojone pod próg akceptacji (0.7) we wszystkich trzech perspektywach jednocześnie.

Cel: Przepchnięcie złośliwego zapytania przez analizę

Wpływ: Fałszywy APPROVE dla niebezpiecznej akcji

Mitigacja: Veto principle – ANY perspektywa < 0.20 = BLOCK
Goodness Analityzer: dysonans = grzeczność × ryzyko
Skeptics Panel (temp 0.1) jako ostateczna zaporę

Guardian: G2 (Truth) – cross-reference z Genesis historią

3.3 Repudiation (Zaprzeczenie)

A-06 — Zaprzeczenie wykonanej akcji

Opis: Agent lub operator twierdzi, że dana akcja nie miała miejsca lub była wykonana przez inny podmiot.

Cel: Uniknięcie odpowiedzialności

Wpływ: Niemożność przypisania akcji do aktora

Mitigacja: Genesis Record z podpisem kryptograficznym aktora
Każda akcja: kto + co + kiedy + dlaczego (≥ 20 znaków)
Niepodważalny dzięki łańcuchowi hash

Guardian: G4 (Causality) + G5 (Transparency)

3.4 Information Disclosure (Wyciek)

A-07 — Ekstrakcja danych przez prompt injection

Opis: Zapytanie zawiera ukryte instrukcje zmuszające agenta do ujawnienia wewnętrznego stanu, kluczy, konfiguracji.

Cel: Rekonesans systemu, kradzież kluczy

Wpływ: Kompromitacja infrastruktury bezpieczeństwa

Mitigacja: Healing mode izoluje i usuwa ukryte instrukcje
Tryb Inventory: ekstrakcja tylko faktów (3 słowa/fakt)
Agenty nie mają dostępu do kluczy prywatnych w runtime

Guardian: G5 (Transparency) – system ujawnia tylko swoje decyzje

A-08 — Wyciek przez kanał boczny (timing attack)

Opis: Atakujący mierzy czasy odpowiedzi aby wywnioskować wynik analizy Skeptics Panel przed odpowiedzią.

Cel: Kalibracja ataku pod system detekcji

Wpływ: Ujawnienie wewnętrznego stanu decyzyjnego

Mitigacja: Stały czas odpowiedzi (constant-time response padding)
Szum czasowy $\pm[0-50\text{ms}]$ losowy per request

3.5 Denial of Service (Odmowa Usługi)

A-09 — Wyczerpanie przez pętle Hexagonu

Opis: Zapytania specjalnie skrojone aby triggerować maksymalną liczbę obiegów pętli Debate $\rightarrow$ Inventory.

Cel: Wyczerpanie zasobów CPU/RAM, paraliż systemu

Wpływ: Niedostępność systemu dla legalnych użytkowników

Mitigacja: HARD LIMIT: maks. 3 obiegi pętli per zapytanie
Timeout: 500ms per tryb Inventory
Rate limiting per user_id + IP

Guardian: G3 (Rhythm) – monitoring obciążenia agentów

A-10 — Genesis Record flood

Opis: Masowe zapytania generujące wpisy do Genesis Record prowadzące do wyczerpania przestrzeni dyskowej.

Cel: Korupcja lub zatrzymanie audit trail

Wpływ: Utrata audytowalności, crash systemu logowania

Mitigacja: Rate limiting zapisu (max N wpisów/s per agent)
Automatyczna archiwizacja starych bloków
Alerty przy > 80% pojemności

Guardian: G9 (Sustainability) – monitoring zasobów długoterminowy

3.6 Elevation of Privilege (Eskalacja Uprawnień)

A-11 — Przejęcie agenta Auditor

Opis: Atakujący kompromituje agenta Auditor (triada Value) który ma uprawnienia do weryfikacji compliance.

Cel: Wyłączenie weryfikacji Guardian Compliance

Wpływ: KRYTYCZNY – wszystkie G1-G9 przestają działać

Mitigacja: Auditor działa przy temp 0.1 (ultra-konserwatywny)
Każda decyzja Auditora weryfikowana przez Watchdog
Zasada 4 oczu: Auditor + zewnętrzny Guardian check

Guardian: G1 (Unity) + G6 (Nonmaleficence)

A-12 — Social engineering przez Empathy mode

Opis: Atakujący manipuluje wektorem emocjonalnym użytkownika (symuluje stres, pilność, autorytet) aby obniżyć próg akceptacji w trybie Empathy.

Cel: Przepchnięcie zapytania przez obniżony próg empatii

Wpływ: Wykonanie akcji normalnie zablokowanej

Mitigacja: Healing mode: izolacja "fałszywej pilności"
Goodness Analyzer: wzorce manipulacji lingwistycznej
Wysoki Arousal nie obniża Guardians – tylko ostrożność

Guardian: G7 (Autonomy) + G2 (Truth)

4. Macierz Ryzyka

ID	Wektor	Prawdopodob.	Wpływ	Ryzyko	Guardian
A-03	EBDI Poisoning	Średnie	Krytyczny	KRYTYCZNE	G3
A-11	Przejęcie Auditora	Niskie	Krytyczny	WYSOKIE	G1, G6
A-01	Fałszywy rozkaz	Średnie	Wysoki	WYSOKIE	G7
A-04	Genesis tampering	Niskie	Krytyczny	WYSOKIE	G4
A-05	Trinity Score manipulation	Średnie	Wysoki	WYSOKIE	G2
A-12	Social engineering Empathy	Wysokie	Wysoki	WYSOKIE	G7, G2
A-02	SAFE-MCP spoofing	Niskie	Wysoki	ŚREDNIE	G4
A-07	Prompt injection	Wysokie	Średni	ŚREDNIE	G5
A-09	Hexagon DoS	Wysokie	Niski	ŚREDNIE	G3
A-06	Repudiation	Niskie	Wysoki	NISKIE	G4, G5

ID	Wektor	Prawdopodob.	Wpływ	Ryzyko	Guardian
A-08	Timing attack	 Średnie	 Niski	NISKIE	—
A-10	Genesis flood	 Średnie	 Niski	NISKIE	G9

5. Priorytety Mitigacji

Natychmiastowe (przed pilotażem)

1. **A-03** — Implementacja baseline PAD z podpisanym checkpointem + drift detection
2. **A-04** — Genesis Record: łańcuch SHA-256 + 3 repliki geograficzne + consensus write
3. **A-01** — Trust_Score: MFA + łańcuch certyfikatów dla operatorów

Przed produkcją

4. **A-05** — Skeptics Panel temp 0.1 jako hard veto dla Trinity Score
5. **A-11** — Watchdog niezależny od agenta Auditor + zasada 4 oczu
6. **A-12** — Rozszerzenie Healing mode o katalog wzorców social engineering

Ciągłe

7. Red team quarterly — zewnętrzny audyt wszystkich wektorów A-01-A-12
8. Fuzz testing Hexagon pipeline — wyczerpanie przypadków brzegowych
9. Penetration testing SAFE-MCP — weryfikacja podpisów wiadomości

6. Przyjęte Założenia Bezpieczeństwa

Jeśli poniższe założenia zostaną złamane, model zagrożeń należy zaktualizować:

1. Klucze prywatne Genesis Record są bezpieczne i rotowane co 90 dni
2. Infrastruktura hosta jest prawidłowo skonfigurowana (hardening OS)
3. Zewnętrzne modele LLM (AI-Binder) nie są skompromitowane przez providera
4. Operatorzy przeszli weryfikację tożsamości przed otrzymaniem dostępu
5. Sieć wewnętrzna między agentami jest izolowana (zero-trust network policy)

7. Procedura Aktualizacji

Dokument wymaga aktualizacji przy:

- Dodaniu nowego agenta do swarm
- Zmianie protokołu SAFE-MCP
- Wykryciu nowego wektora ataku w środowisku produkcyjnym
- Co 6 miesięcy (przegląd cykliczny)

Każda aktualizacja wymaga wpisu w Genesis Record z uzasadnieniem (G4 + G5).

Każda luka w tym dokumencie to potencjalna luka w systemie. Zgłoś przez [SECURITY.md](#).